

Análise da Criptografia Ponta-a-Ponta

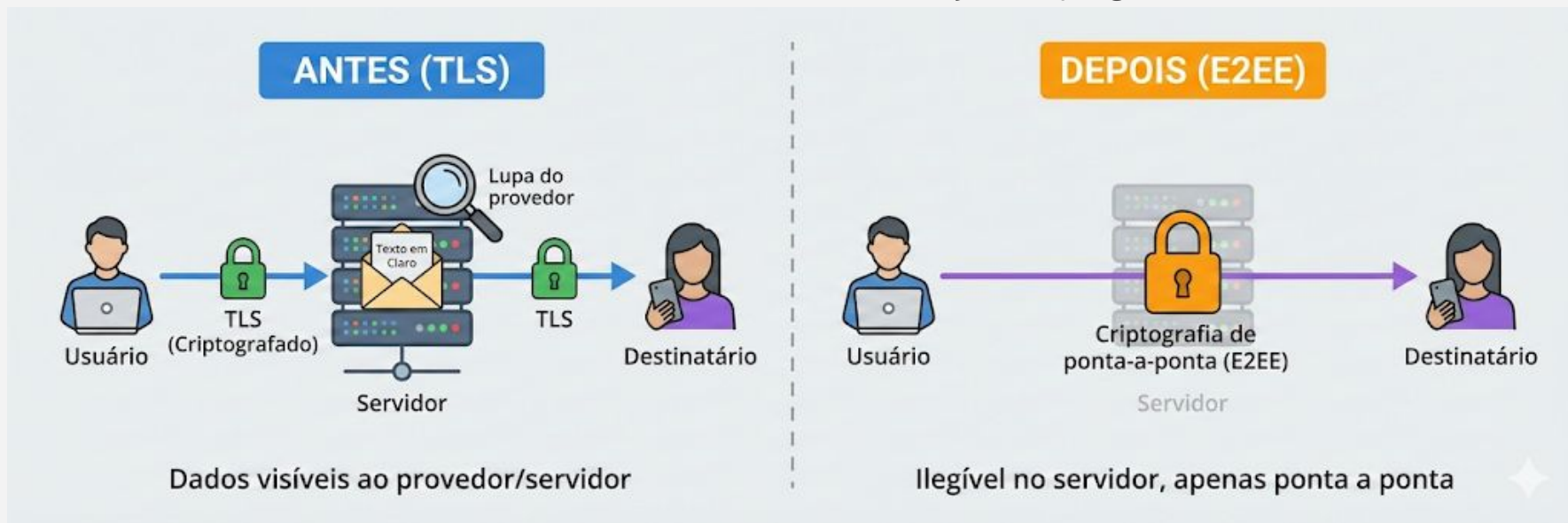
Um Estudo sobre o Protocolo Signal e suas
implementações

◆ ◆
Max José, Luiz Leite e Wesley Pontes



A Mudança de Paradigma na Mensageria

- ❑ Limitações da Criptografia de Transporte (TLS/SSL).
- ❑ O provedor como “ponto único de falha” (Contexto pós-2013/Snowden).
- ❑ A solução: Criptografia End-to-End



A Origem e o “Axolote”



Criado pela Open Whisper Systems
(Moxie Marlinspike e Trevor Perrin).

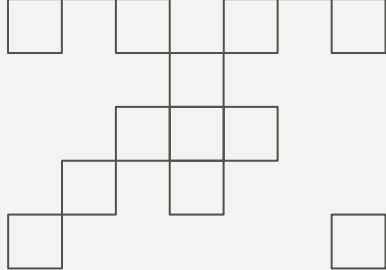


O padrão de facto da indústria
(usado por WhatsApp, Skype, etc.).

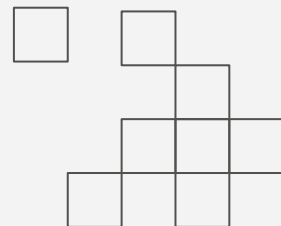


Codínome original: Axolotl.





Conceitos Básicos

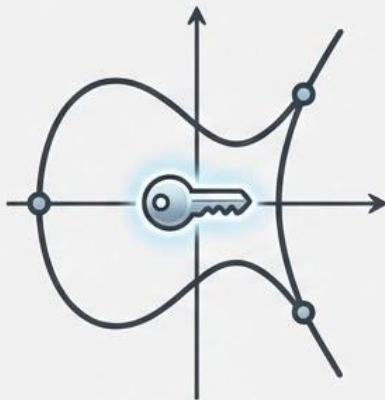


Primitivas Criptográficas Base



Criptografia Híbrida

(Assimétrica para chaves,
Simétrica para mensagens).



ECDH (Elliptic-Curve Diffie-Hellman)

O pulo do gato: Troca de
chaves segura.



Otimização para Mobile (Curve25519)

Foco em desempenho e
segurança em dispositivos.



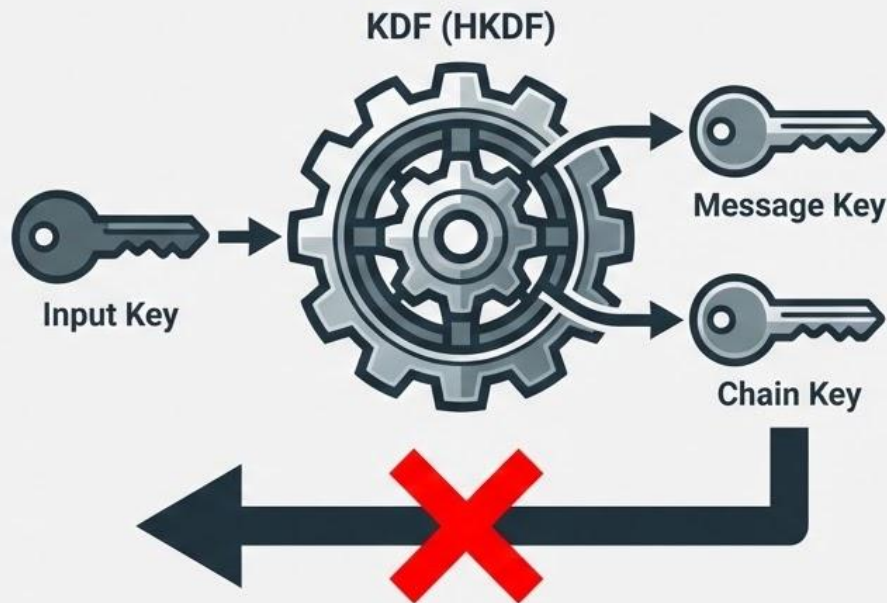
Função de Derivação de Chaves (KDF)



HKDF (Baseada em HMAC-SHA256).



A importância da **Unidirecionalidade**.



Propriedades Avançadas: Forward Secrecy



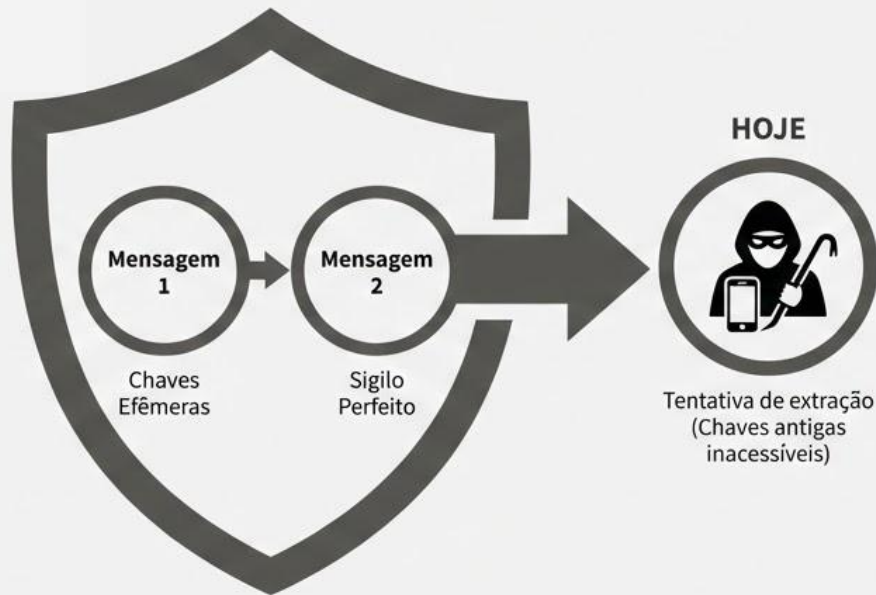
Sigilo Perfeito Encaminhado.



Uso intensivo de chaves efêmeras.



Proteção contra a extração futura de chaves de longo prazo.



Propriedades Avançadas: Post-Compromise Security



O Desafio dos Metadados (Sealed Sender)



Criptografia protege o conteúdo ("a carta").



Metadados expõem o comportamento ("o envelope").



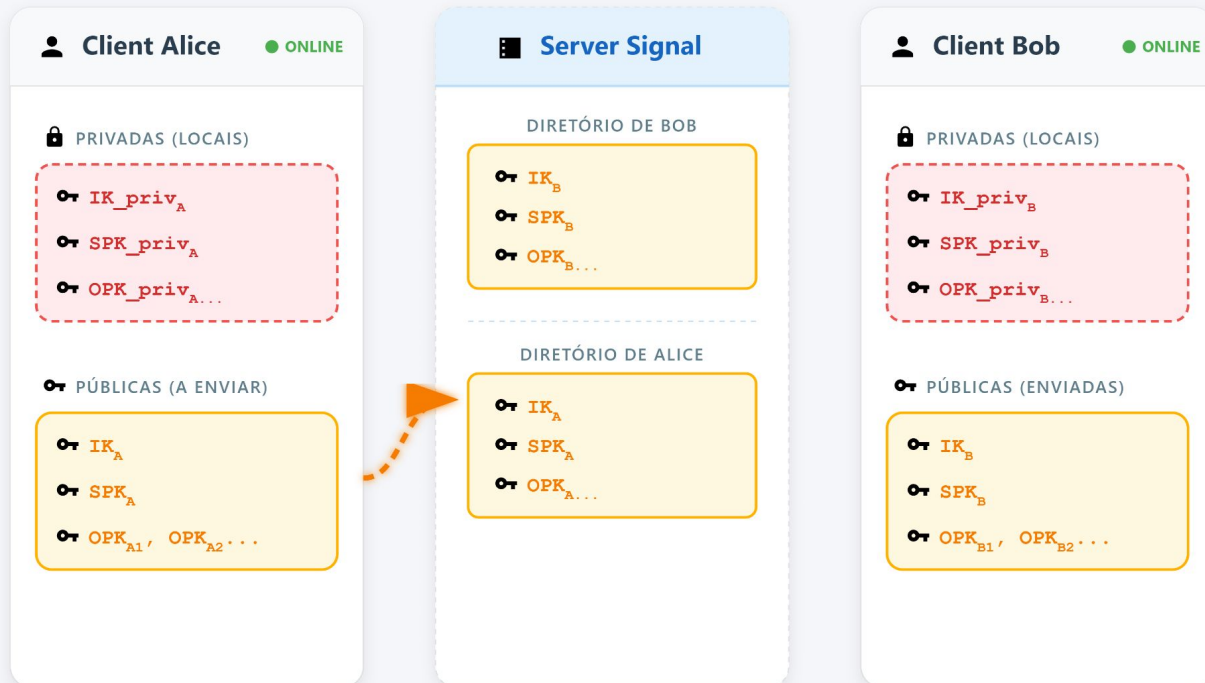
Sealed Sender: Ocultando o remetente do servidor.



O Protocolo Signal Ilustrado



Ato 1.5 - Alice registra suas Pre-Keys



Ato 1 - Infraestrutura de Chaves (Pre-Keys)

 Client Signal Alice



(Não instalado)

 Server Signal

 Client Signal Bob

 CHAVES PRIVADAS (LOCAIS)

 `IK_privB`

 `SPK_privB`

 `OPK_privB...`

Ato 1 - Infraestrutura de Chaves (Pre-Keys)

 Client Signal Alice



(Não instalado)

 Server Signal

 Client Signal Bob

 CHAVES PRIVADAS (LOCAIS)

 IK_{priv_B}
 SPK_{priv_B}
 $OPK_{priv_{B...}}$

 CHAVES PÚBLICAS (A ENVIAR)

 IK_B
 SPK_B
 $OPK_{B1}, OPK_{B2}...$

Ato 1 - Infraestrutura de Chaves (Pre-Keys)



Client Signal Alice



(Não instalado)



Server Signal



Client Signal Bob



CHAVES PRIVADAS (LOCAIS)



IK_{priv_B}



SPK_{priv_B}



$OPK_{priv_{B...}}$



CHAVES PÚBLICAS (A ENVIAR)



IK_B



SPK_B



$OPK_{B1}, OPK_{B2}...$



Ato 1 - Infraestrutura de Chaves (Pre-Keys)

 Client Signal Alice



(Não instalado)

 Server Signal

DIRETÓRIO DE BOB

 IK_B
 SPK_B
 $OPK_{B1}, OPK_{B2} \dots$

 Client Signal Bob

 CHAVES PRIVADAS (LOCAIS)

 IK_{priv_B}
 SPK_{priv_B}
 $OPK_{priv_{B\dots}}$

 CHAVES PÚBLICAS (A ENVIAR)

 IK_B
 SPK_B
 $OPK_{B1}, OPK_{B2} \dots$

Ato 1.5 - Alice registra suas Pre-Keys

 Client Alice

 PRIVADAS (LOCAIS)

 IK_{priv_A}
 SPK_{priv_A}
 $OPK_{priv_{A...}}$

 Server Signal

DIRETÓRIO DE BOB

 IK_B
 SPK_B
 $OPK_{B...}$

 Client Bob ● ONLINE

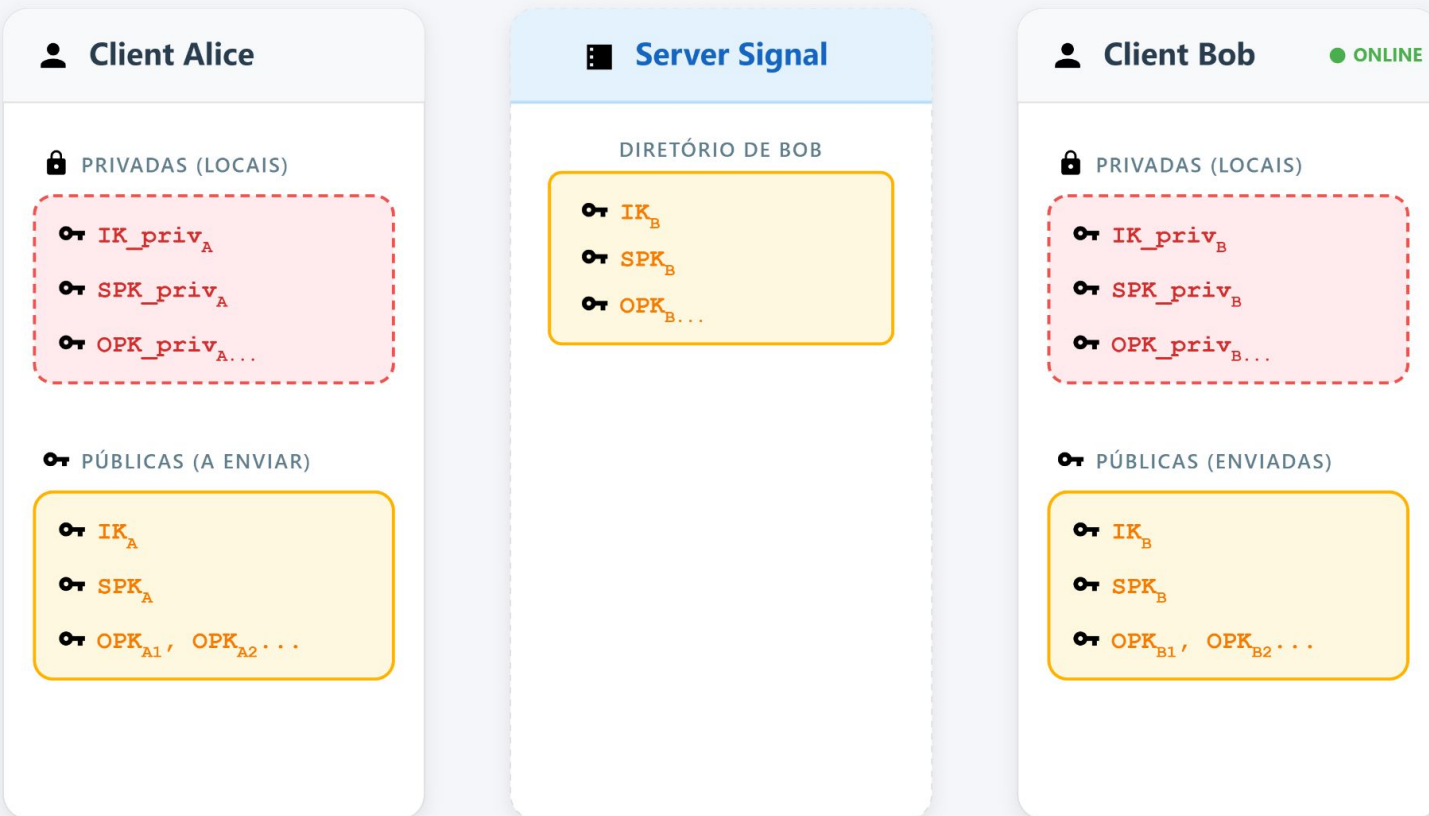
 PRIVADAS (LOCAIS)

 IK_{priv_B}
 SPK_{priv_B}
 $OPK_{priv_{B...}}$

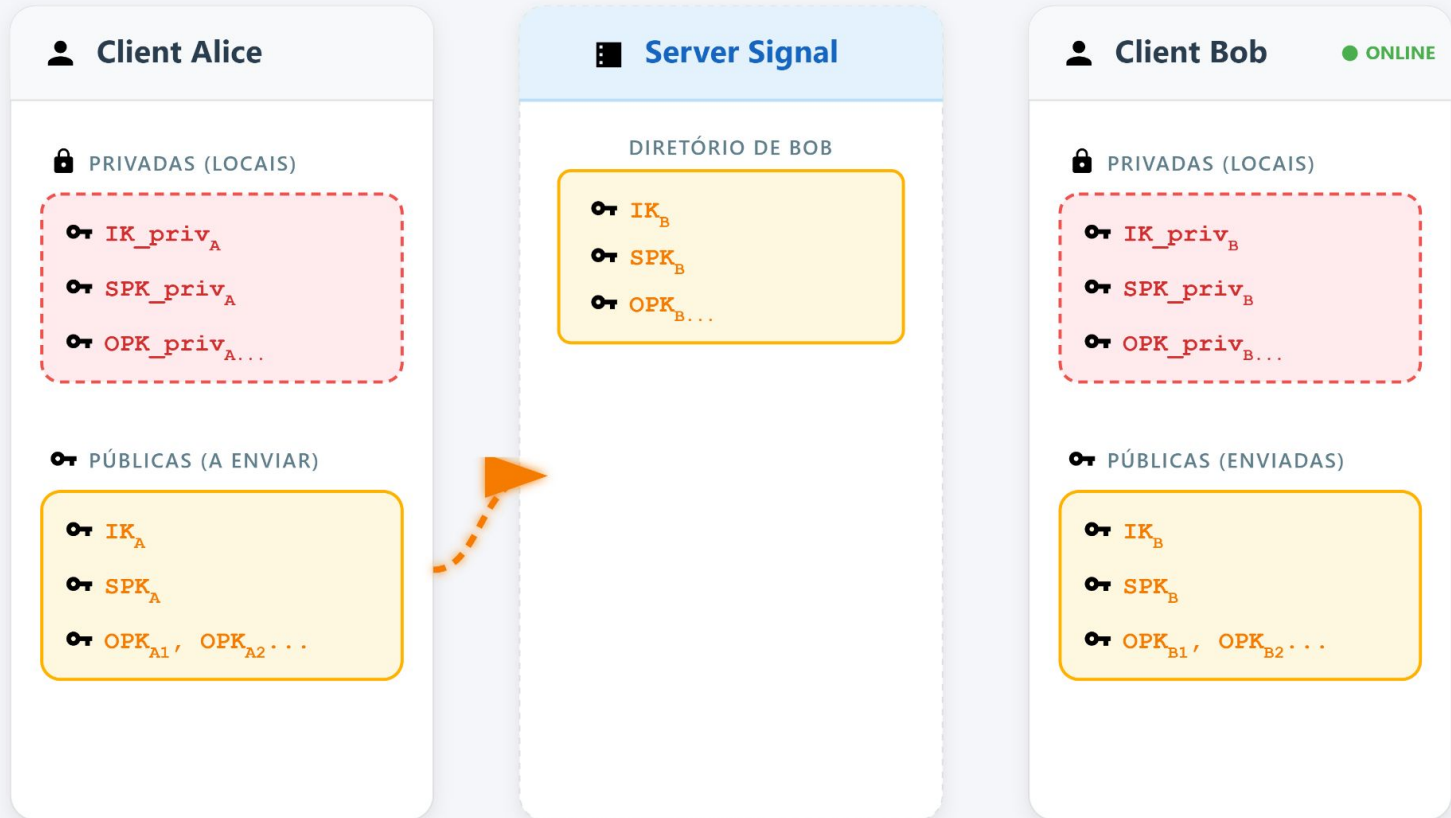
 PÚBLICAS (ENVIADAS)

 IK_B
 SPK_B
 $OPK_{B1}, OPK_{B2}...$

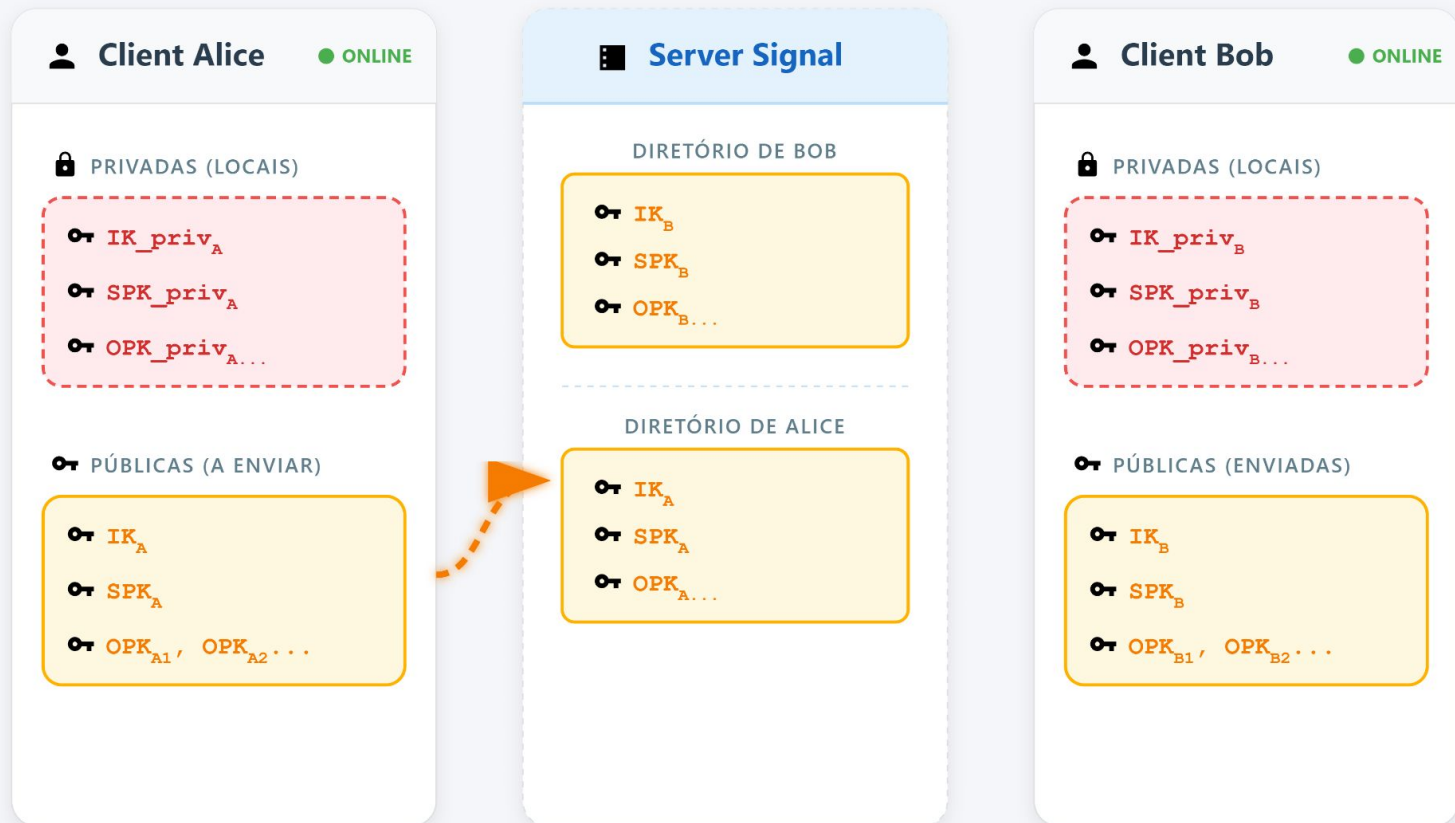
Ato 1.5 - Alice registra suas Pre-Keys



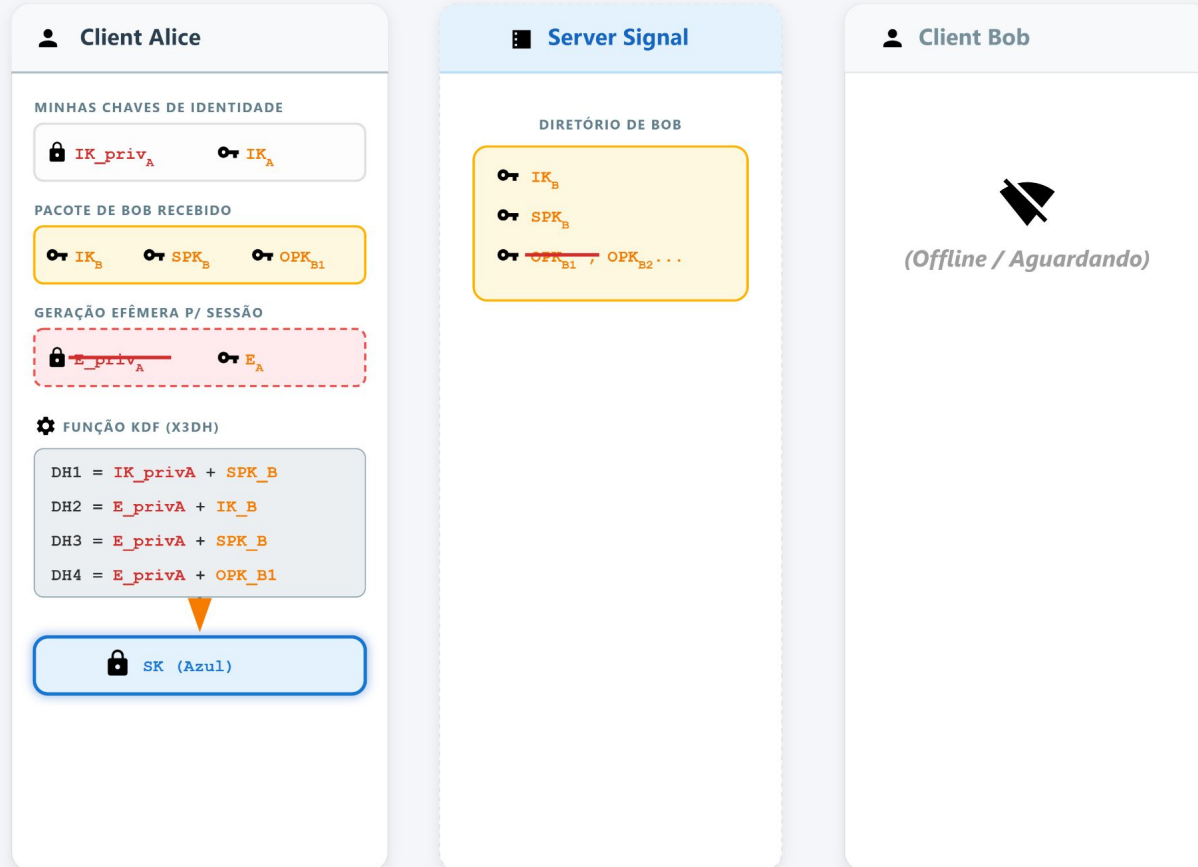
Ato 1.5 - Alice registra suas Pre-Keys



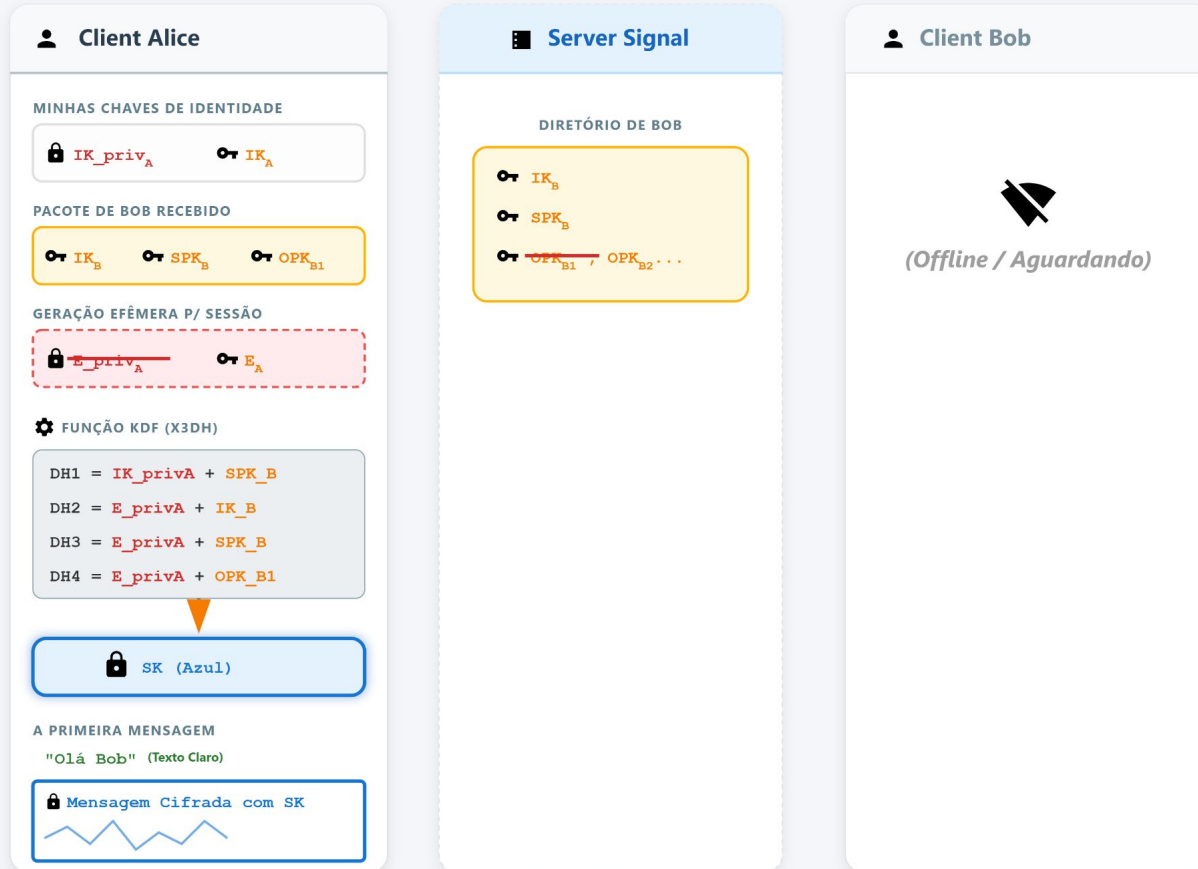
Ato 1.5 - Alice registra suas Pre-Keys



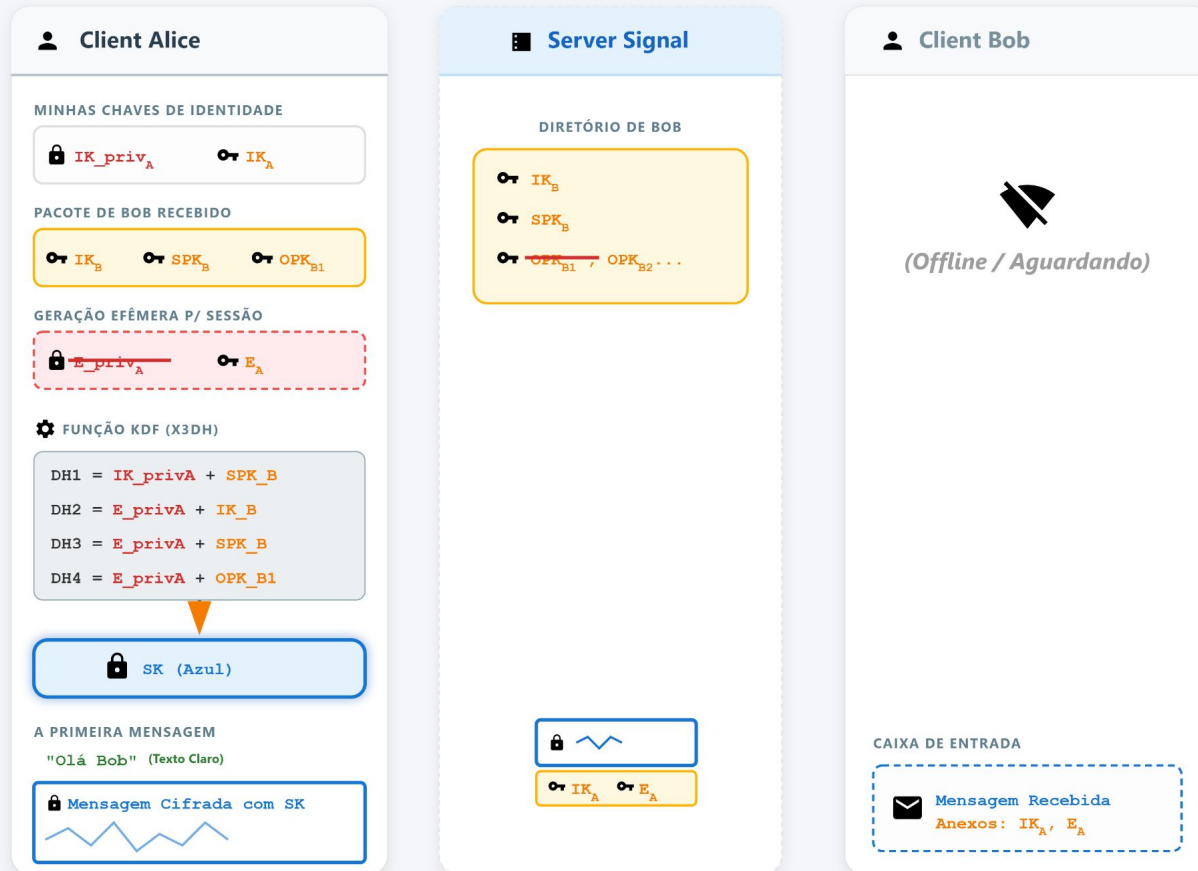
Ato 2 - O Estabelecimento de Sessão (X3DH)



Ato 2 - O Estabelecimento de Sessão (X3DH)

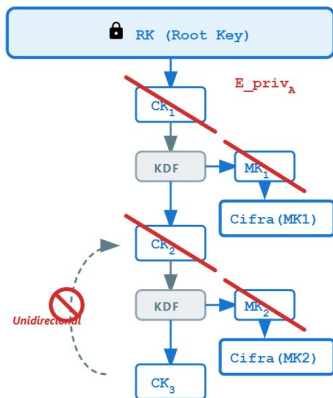


Ato 2 - O Estabelecimento de Sessão (X3DH)



Ato 3 - O Algoritmo Double Ratchet

Client Alice (Enviando)



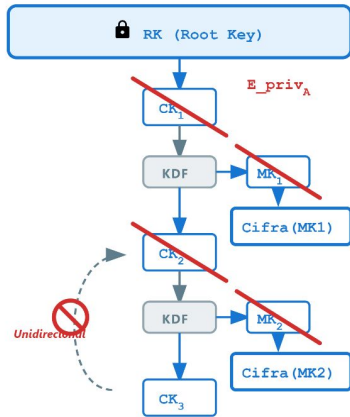
Server (Roteador)

APENAS REPASSA PACOTES CIFRADOS

Client Bob (Respondendo)

Ato 3 - O Algoritmo Double Ratchet

Client Alice (Enviando)



Server (Roteador)

APENAS REPASSA PACOTES CIFRADOS

Client Bob (Respondendo)

NOVO PAR EFÊMERO (RATCHET DH)

$E_{priv_{B2}}$ E_{B2} (Pública)

MENSAGEM DE RESPOSTA

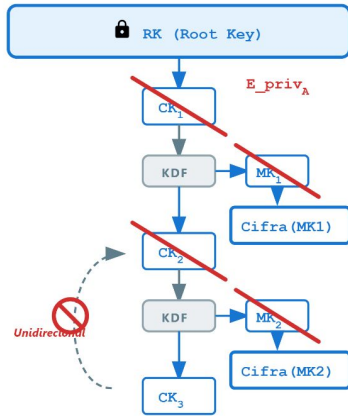
"Tudo ótimo!"

Cifra Bob (MK_B1)

PACOTE PRONTO PARA ENVIO

Ato 3 - O Algoritmo Double Ratchet

Client Alice (Enviando)



Server (Roteador)



Client Bob (Respondendo)

NOVO PAR EFÊMERO (RATCHET DH)

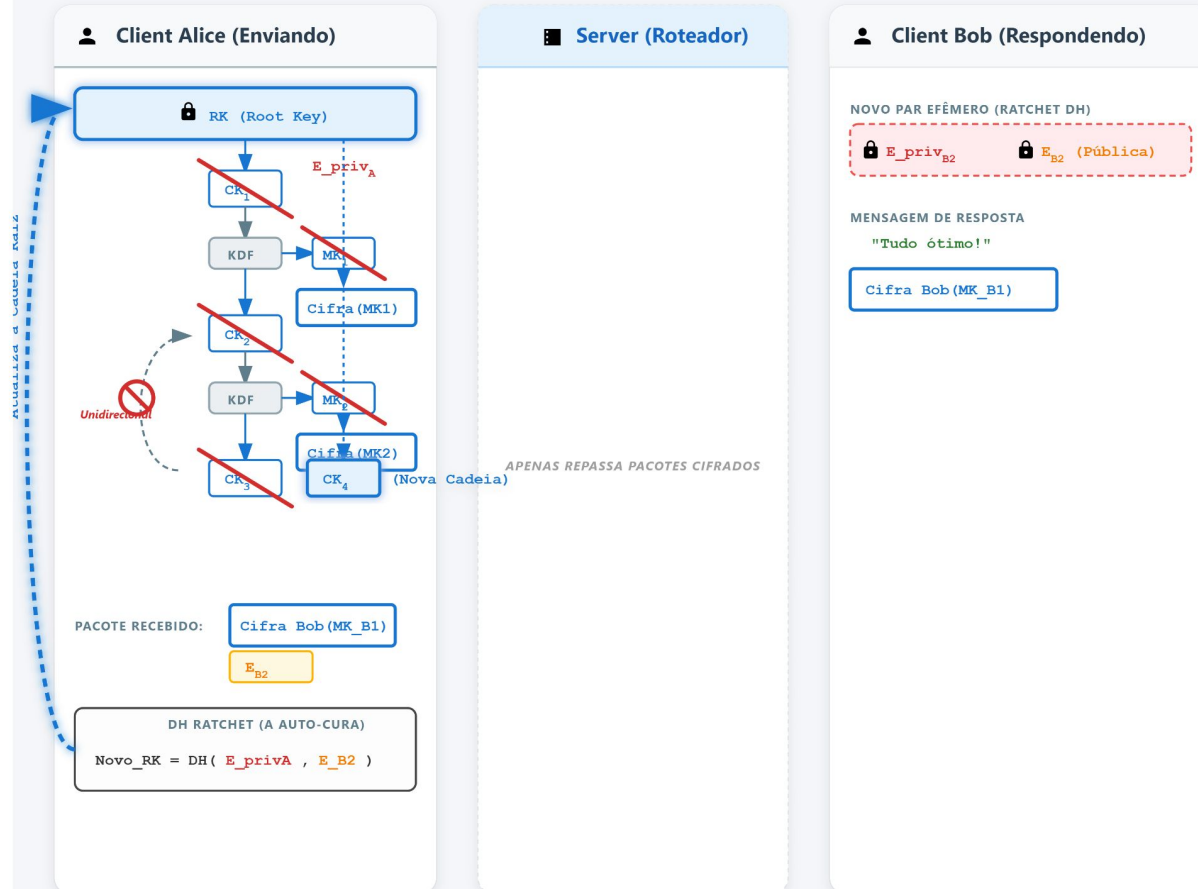
$E_{priv_{B2}}$ E_{B2} (Pública)

MENSAGEM DE RESPOSTA

"Tudo ótimo!"

Cifra Bob (MK_B1)

Ato 3 - O Algoritmo Double Ratchet



1. Adaptação do Signal no WhatsApp □ □



- O WhatsApp adapta o Signal para funcionar de forma eficiente em bilhões de dispositivos móveis.

- A arquitetura resolve problemas práticos como comunicação assíncrona, envio de arquivos e escalabilidade em grupos.



1. Adaptação do Signal no WhatsApp

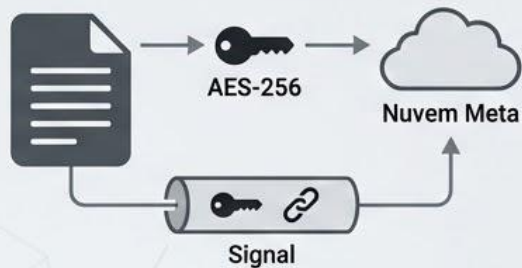
- ❑ O servidor atua como um intermediário na troca de chaves públicas para permitir mensagens a usuários offline.
 - ❑ Chave de Identidade: A identidade permanente do dispositivo.
 - ❑ Chave Pré-assinada: Uma chave renovada periodicamente e assinada pela chave de identidade.
 - ❑ Lotes de Chaves de Uso Único (One-Time Pre-Keys): Chaves descartáveis usadas para aumentar a segurança de cada nova sessão.
- ❑ O servidor facilita o encontro dessas chaves públicas, mas não possui acesso às chaves privadas.

O Algoritmo de Catraca Dupla (Double Ratchet)



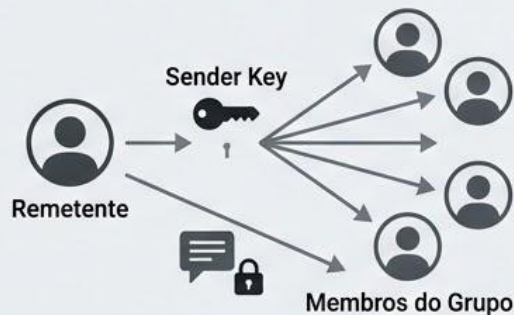
Tratamento de Arquivos, Escala em Grupos e Comunicação em Tempo Real

Tratamento de Mídia e Arquivos Grandes



O Double Ratchet não é otimizado para arquivos grandes. Mídia é cifrada com chave simétrica temporária (AES-256) e enviada à nuvem da Meta. Apenas a chave e o link trafegam pelo Signal.

Escalabilidade em Grupos (Sender Keys)



Utiliza-se Sender Keys para evitar cifrar a mesma mensagem múltiplas vezes. O remetente gera e distribui a chave; mensagens subsequentes são cifradas apenas uma vez.

Comunicação em Tempo Real (Voz e Vídeo)



O Protocolo Signal negocia a chave secreta inicial. Após o atendimento, o fluxo contínuo de mídia é transmitido via SRTP.

4. O Tesouro da Meta: Metadados



- O modelo de negócios da Meta baseia-se na exploração de metadados, apesar da criptografia proteger o conteúdo das mensagens.



- Enquanto a criptografia protege a “carta”, os metadados são as informações do lado de fora do “envelope”.



- O WhatsApp centraliza metadados como: contatos, frequência de interações, horários, localização e dados do aparelho.



- A atualização obrigatória de 2021 permitiu que a Meta acessasse metadados de interações com Contas Comerciais para direcionar anúncios.



5. Implicações Práticas e Ordens Judiciais.

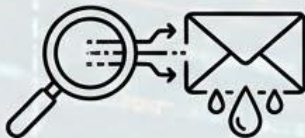


- O conteúdo de mensagens e mídias é inacessível à justiça (códigos ilegíveis).
- A riqueza dos metadados fornece informações táticas fundamentais.
- A Meta pode entregar a teia de contatos, dados de grupos e vínculos (Facebook/Instagram).
- Permite mapear a rede de relacionamentos de uma investigação, sem ler as conversas.

Conclusão



Protocolo Signal: Padrão de facto, garantindo Sigilo Perfeito e Segurança Pós-Comprometimento para o conteúdo (X3DH, Double Ratchet).



Desafio dos Metadados: Cifragem ponta-a-ponta não impede perfilagem. Arquiteturas centralizadas (ex: WhatsApp) expõem metadados críticos.



Alternativas Federadas: Protocolo Matrix oferece viabilidade para ambientes federados, adaptando-se para escalabilidade (Megolm).



A segurança na mensageria moderna transcende a robustez dos algoritmos; depende de decisões arquiteturais que minimizem a coleta de metadados e respeitem a soberania dos dados.



Análise da Criptografia Ponta-a-Ponta

Por

WESLEY BARBOSA

wesley.pontes.barbosa@icen.ufpa.br

MAX JOSÉ

max.junior@icen.ufpa.br

LUIZ LEITE

luiz_fleite@outlook.com

